

State of Maine

Department of Administrative and Financial Services

Office of Information Technology

Configuration Management Policy and Procedures (CM)

Configuration Management Policy and Procedures (CM)

Table of Contents

1.0. Document Purpose 2

2.0. Scope 2

3.0. Policy Conflict 2

4.0. Roles and Responsibilities 2

5.0. Management Commitment 3

6.0. Coordination Among Agency Entities 3

7.0. Compliance 3

8.0. Procedures 4

9.0. Document Details 16

10.0. Review 16

11.0. Records Management 16

12.0. Public Records Exceptions 17

13.0. Definitions 17

14.0. Abbreviations 19

1.0. Document Purpose

The purpose of this document is to define the State of Maine policy and procedures that are in place to ensure appropriate configuration methods are applied in maintaining State of Maine information assets (see Definitions). This part of the security program is focused on protecting the confidentiality (see Definitions), integrity (see Definitions), and availability (see Definitions) of State information assets. This document corresponds to the Configuration Management Policy and Procedures (CM) Control Family of National Institute of Standards and Technology (NIST) Special Publication 800-53 (Rev. 5).[1].

2.0. Scope

2.1. This policy applies to all State of Maine employees and contractors (collectively referred to as personnel in this document) with access to:

2.1.1. Executive Branch Agency information assets, irrespective of location; and

2.1.2. Information assets from other State government branches that use Executive Branch-managed services.

3.0. Policy Conflict

If this policy conflicts with any law or union contract in effect, the terms of the existing law or contract prevail.

4.0. Roles and Responsibilities

4.1. Agency Business Partners:

4.1.1. In collaboration with OIT Information Asset Owners and I.T. Procurement, hold contracted other parties that host State information assets accountable to this Policy and Procedures.

4.1.2. Develop and implement Agency-level policy and procedures to meet any additional statutory requirements or Agency-specific controls.

4.2. I.T. Procurement:

4.2.1. In collaboration with Agency Business Partners and Information Asset Owners, hold contracted other parties that host State information assets accountable to this Policy and Procedures.

4.3. OIT Change Advisory Board Chairs:

4.3.1. Develops, maintains, and enforces requirements of Configuration Management, in alignment with the Change Management Policy.[2]

---

1 https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

2 https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ChangeManagementPolicy.pdf

4.4. OIT Client Technology Services:

4.4.1. Uses a configuration manager to enforce software standards for managed software only on endpoints.

4.4.2. Provides customer support for the installation of approved applications on end-user devices.

4.5. OIT Computing and Infrastructure Services:

4.5.1. Maintains a workflow for managing trusted PKI certificates.

4.6. OIT Enterprise Architecture and Policy:

4.6.1. Develops and maintains a list of approved technologies for use by the State Executive Branch and the Statewide area network.

4.7. OIT Information Asset Owners:

4.7.1. Comply with this Policy and Procedures regarding configuration management.

4.7.2. In collaboration with Agency Business Partners and I.T. Procurement, hold contracted other parties that host State information assets accountable to this Policy and Procedures.

4.8. OIT Information Security Office:

4.8.1. Owns, executes, and enforces this Policy and Procedures.

4.8.2. Provides oversight of the security functions of the State's Security Information and Event Management system.

4.9. OIT Network Services:

4.9.1. Enforces controls of network infrastructure devices connecting to State resources.

5.0. Management Commitment

The State of Maine is committed to following this policy and the procedures that support it.

6.0. Coordination Among Agency Entities

6.1. Agency Business Partners will cooperate with OIT in executing this Policy and Procedures.

6.2. The Information Security Office will continuously monitor the Change Management process to ensure consistent risk-based processes.

6.3. OIT coordinates with various divisions and agency business partners to execute this policy and procedures.

7.0. Compliance

7.1. For State of Maine employees, failure to comply with this document may result in progressive discipline, up to and including dismissal.

7.2. For State of Maine contractors and non-State of Maine personnel, failure to comply may result in the removal of the individual's ability to access and use State of Maine data and systems. Employers of contractors will be notified of any violations.

7.3. Personnel are also subject to any applicable penalties for statutory requirements compliance violations. Depending on the requirement and the nature of the violation, penalties could include fines and/or criminal charges.

8.0. Procedures

The following standards apply to and represent the security controls established to meet an acceptable level of protection for the State of Maine's information assets through the configuration and change management process.

8.1. **Governance Controls: Policy and Procedures (CM-1) -** The Office of Information Technology (OIT) develops, approves, disseminates, and reviews this policy in accordance with Sections 9.0 (Document Details) and 10.0 (Review).
These sections collectively satisfy NIST SP 800-53 Revision 5 control one (1) requirements for defining, approving, disseminating, and periodically reviewing policy and procedures for this control family.

8.2. **Baseline Configuration (CM-2, (2), (3), (6), (7))**

8.2.1. **Develop and Maintain Baseline Configuration (CM-2)** - OIT Information Asset Owners develop, document, and maintain a current baseline configuration of the information systems under their purview. Baseline configurations serve as the foundation for all builds, releases, and changes to information systems. Maintaining baseline configurations requires creating new baselines as information systems change over time. To the maximum extent possible, baseline configurations are dictated by standards bodies (such as the CIS Benchmarks,[3] IRS Safeguards Benchmarks,[4] etc.), or by trusted product vendors (such as Microsoft, Oracle, etc.).

8.2.2. **Device Compliance Requirements (CM-2)** - Any authorized consumer device with an operating system seeking to attach to the Statewide area network must meet the following minimum criteria (see Mobile Device Policy[5]):

8.2.2.1. Supported operating systems: Windows, Android, iOS;

8.2.2.2. All critical operating system and Security patches have been applied within the previous 30 calendar days;

8.2.2.3. Have an antimalware listed in the Leaders quadrant of the latest Gartner Magic Quadrant for Endpoint Protection

[3] https://www.cisecurity.org/cis-benchmarks/
[4] https://www.irs.gov/privacy-disclosure/safeguards-program
[5] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/MobileDevicePolicy.pdf

Platforms (EPP), and *not* blacklisted by any arm of the U.S. Federal Government; and

8.2.2.4. The anti-malware data file was updated within the previous 15 calendar days.

8.2.3. **Network Enforcement Controls (CM-2)** - Network Services uses various network administration products to enforce controls of devices on the network as directed by the Chief Information Security Officer (CISO).

8.2.3.1. For devices connected to the Statewide area network, OIT must have at least read-only access.

8.2.3.2. Devices connected to the wide area network may be quarantined, disconnected, and/or impounded for any reason, including but not limited to, potential malware, device type, and configuration not in alignment with OIT standards, adverse impact to the network, excessive bandwidth utilization, or non-payment of OIT-related charges, etc.

8.2.4. **Reviews and Updates (CM-2(1))** - OIT Information Asset Owners review and update the baseline configuration of information systems as an integral part of information system component installation and upgrades. This review is undertaken at least once every calendar year, as well as when configuration changes are made due to critical security patches, upgrades, and emergency changes (e.g., unscheduled changes, system crashes, and replacements of critical components). Any and all security patching and emergency changes are subject to the Change Management Policy.[6] All major changes, with a moderate or high impact risk, are subject to either the Application Deployment Certification Policy,[7] or the Infrastructure Deployment Certification Policy.[8]

8.2.5. **Retention of Previous Configurations (CM-2(3)) -** As part of standard Change Management, OIT Information Asset Owners retain at least one previous stable version of the baseline configuration of all information systems to support rollback.

8.2.6. **Development and Test Environments (CM-2(6)) -** OIT Information Asset Owners maintain baseline configurations of development and test environments, which are managed separately from the operational (production) baseline configurations.

8.2.7. **Configure Systems and Components for High-Risk Areas (CM-2(7)) -** OIT Managers refer to travel guidance set by the U.S. Secretary of State

[6] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ChangeManagementPolicy.pdf
[7] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ApplicationDeploymentCertification.pdf
[8] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/Infrastructure-Deployment-Certification.pdf

and consult with the Information Security Office (ISO) prior to approving work outside the United States by any OIT personnel or contractor. Agencies should establish similar controls.

8.2.7.1. When agency personnel travel, and/or engage in remote work, abroad, especially in high-risk areas, OIT issues extra-hardened (more stringent configuration settings (see Definitions)), and stripped-down devices (notebooks and phones) to such agency personnel. These devices do *not* have any non-relevant apps.

8.2.7.2. Upon personnel's return to Maine, these devices (i.e., notebooks and phones) are reset to factory defaults before being returned to the OIT device fleet.

8.2.8. **Automation Support for Accuracy and Currency (CM-2(2)) -** OIT Information Asset Owners must maintain the currency, completeness, accuracy, and availability of all baseline configurations using automated mechanisms. Automation ensures consistency and rapid detection of unauthorized or outdated configurations. At a minimum:

8.2.8.1. System baselines are maintained within approved enterprise repositories such as GitHub Government, JIRA/Confluence Government, and IT Service Management (ITSM) platforms.

8.2.8.2. Baseline configurations align with vendor-provided or consensus-based benchmarks, including Center for Internet Security (CIS) Benchmarks and IRS Computer Security Evaluation Matrix (SCSEM).

8.2.8.3. Automation accounts and service identities supporting configuration management are access-controlled per the Access Control Policy[9].

8.2.8.4. Automated vulnerability management tools continuously identify misconfigurations or deviations from approved baselines.

8.2.8.5. Designated build teams maintain "golden images" to ensure all new systems deploy with secure, standardized configurations.

8.2.8.6. Baseline compliance is monitored through the Continuous Monitoring Program, with exceptions tracked and remediated through established change management procedures.

[9] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/AccessControlPolicy.pdf

8.3. Configuration Change Control (CM-3, (2), (4))

8.3.1. **Configuration Change Control (CM-3) -** Any changes to the baseline configuration are undertaken strictly according to the Change Management Policy.[10] This involves the systematic proposal, justification, implementation, testing, review, and disposition of changes, including system upgrades and modifications. This also includes emergency changes to remediate vulnerabilities that are suddenly discovered. The Change Advisory Board must approve changes without exception. Auditing of changes includes activities before and after changes are made, and the actual steps required to implement such changes.

8.3.1.1. Configuration change proposal is explicitly reviewed for its security impact, as well as its potential impact on end users.

8.3.1.2. For any information asset, configuration change decisioning, as well as the implementation details, are documented, and the resulting audit trail is retained for as long as OIT remains invested in that information asset.

8.3.1.3. Coordination and oversight of the configuration change control is provided by the Change Advisory Board on a weekly basis.

8.3.2. **Configuration Change Control (CM-3) -** Change Management logs are available for review reactively as part of any troubleshooting, and incident response/management.

8.3.3. **Configuration Change Control (CM-3) -** All configuration changes are documented in the enterprise ticketing application.

8.3.4. **Configuration Change Control (CM-3) -** For each configuration change, stakeholders (identified by their email addresses) are explicitly identified in the change ticket, and each of them receives an automated notification for every change in the ticket.

8.3.5. **Configuration Change Control (CM-3) -** No actual configuration change may proceed without the explicit approval of the Change Advisory Board.

8.3.5.1. Proposed changes that are not yet approved by the Change Advisory Board are clearly flagged as Not-Yet-Approved.:

8.3.5.2. Relevant details of the proposed change must be documented within the change ticket. This is an essential prerequisite for approval by the Change Advisory Board.

[10] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ChangeManagementPolicy.pdf

8.3.5.3. Stakeholders are automatically notified through email when approved changes are completed.

8.3.6. **Testing, Validation, and Documentation of Changes CM-3(2)** - OIT Information Asset Owners test, validate, and document changes to information assets before implementing the changes to the operational (production) systems. The burden of initiating and coordinating the testing, validation, and documentation rests with the Change Initiator, who represents the Information Asset Owner. Individuals and groups conducting such tests understand and comply with the information system security policies and procedures, as well as the specific health, safety, and environmental risks associated with particular facilities/processes.

8.3.7. **Configuration Change Control (CM-3) -** To the maximum extent possible, OIT Information Asset Owners employ automated mechanisms to implement changes to the current configuration baselines and deploy the updated baselines across the enterprise. Such automation tools include Microsoft System Center Configuration Manager, Chef, Puppet, Docker, etc.

8.3.8. **Security and Privacy Representatives CM-3(4) -** The Information Security Office has a permanent representative on the Change Advisory Board.

8.3.9. **Configuration Change Control (CM-3) -** Logs are ingested into the enterprise Security Information and Event Manager and are monitored by a third-party vendor. Suspicious behavior is detected, generating an email alert to the Information Security Office. This is a matter that warrants immediate investigation by the CISO.

8.3.10. **Configuration Change Control (CM-3) -** There exists a strictly controlled process for generating, tracking, and renewing trusted OIT Public Key Infrastructure (PKI, see Definitions) certificates. This is based on best practices of Microsoft Windows Server Active Directory Certificate Services, and is built into the enterprise Active Directory.

8.4. **Security Impact Analysis (CM-4, (1), (2))**

8.4.1. **Security Impact Analysis (CM-4)** – The Change Advisory Board analyzes changes to the information system to determine potential security impacts prior to change implementation. The standing member of the Information Security Office on the Change Advisory Board conducts security impact analyses. Security impact analyses include, at a minimum, assessments of risk to forecast the impact of the changes and to determine if additional security controls are necessary. Security impact analyses are scaled in accordance with the security categories of the information systems.

8.4.2. **Separate Test Environments CM-4(1)** - OIT Information Asset Owners analyze changes to the information system in a separate test environment before implementation in an operational (production) environment. Information Asset Owners investigate the security impacts of flaws, weaknesses, incompatibilities, or intentional malice.

8.4.3. **Post-Implementation Verification CM-4(2) -** After an information system is changed, OIT Information Asset Owners check the security functions to verify that the functions are implemented correctly, operating as intended, and producing the desired outcome to meet the security requirements for the system. Any anomaly is escalated to the Information Security Office.

8.5. **Access Restrictions for Change (CM-5, (1), (5), (6))**

8.5.1. **Access Restrictions for Change (CM-5) -** OIT defines, documents, approves, and enforces access restrictions associated with configuration changes to information systems, per the Access Control Policy.[11]

8.5.2. **Access Restrictions for Change (CM-5) -** Only authorized system administrators can make configuration changes, including upgrades and modifications.

8.5.3. **Log System Accesses CM-5(1)** - Detailed records of administrative access are maintained for the lifetime of an information asset. This is to ensure that configuration change control is implemented, and to support after-the-fact actions, should any unauthorized changes be discovered.

8.5.4. **Log System Accesses CM-5(1)** - OIT enforces strict administrative access restrictions and has hired a third-party vendor to conduct log analysis in the Security Information and Event Manager. Dashboards can be created in the Security Information and Event Manager to provide on-demand reporting as required.

8.5.5. **Limit Privileges to Change Operational Systems CM-5(5) -** Only authorized system administrators can make configuration changes in the production/operational instance. OIT enforces strict administrative access restrictions and implements auditing of said enforcement via log analysis in the Security Information and Event Manager. All OIT Managers (the managers of the various information asset teams) review and re-evaluate system administrator privileges at each employee transition, and as part of the annual performance management cadence.

8.5.6. **Software Libraries Include Privileged Programs CM-5(6) -** Only authorized system administrators can make configuration changes to software resident within software libraries and source control repositories. All OIT Managers (the managers of the various information

[11] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/AccessControlPolicy.pdf

asset teams) review and re-evaluate system administrator privileges at each employee transition, and as part of the annual performance management cadence.

8.6. **Configuration Settings (CM-6, (1), (2))**

8.6.1. **Establish and Implement Secure Configuration Settings (CM-6) -** OIT Information Asset Owners establish, document, and implement Common Secure Configurations (see Definitions) for information assets, using either industry standards bodies (such as the National Institute of Standards and Technology,[12] CIS Benchmarks,[13] IRS Safeguards Benchmarks,[14] etc.), or trusted product vendors (such as Microsoft, Oracle, etc.). The purpose is to determine the most restrictive mode that is consistent with operational requirements.

8.6.2. **Waiver and Compensating Controls (CM-6) -** Any deviation from the established configuration settings must go through an explicit waiver from the CISO. Approval for such a waiver is contingent upon furnishing a non-trivial business case and demonstrating suitable compensating controls.

8.6.3. **Automated Management and Response to Unauthorized Changes (CM-6(1), (2)) -** Logs are ingested into the enterprise Security Information and Event Manager and are monitored by a third-party vendor. Any suspicious behavior detected triggers an email alert to the Information Security Office. This is a matter that warrants immediate investigation by the CISO. Depending upon the outcome of that investigation, the original configuration settings (i.e., the state prior to the unauthorized changes) may be restored, and/or the affected information asset may be quarantined, and/or the affected information system may be temporarily taken out of service, and/or a potential disciplinary action may be initiated.

8.7. **Least Functionality (CM-7, (1), (2), (5), (9))**

8.7.1. **Establish and Maintain Least Functionality (CM-7) -** OIT Information Asset Owners configure information assets to provide only the essential capabilities, commensurate with agency customer business requirements. OIT Information Asset Owners disable functions, ports, protocols, and services not explicitly required for executing agency business and customer business requirements.

8.7.2. **Review of Functions, Ports, and Services (CM-7 (1)) -** To the maximum extent feasible under budgetary constraints, information assets are configured and optimized for the narrowest range of

[12] https://www.nist.gov/
[13] https://www.cisecurity.org/cis-benchmarks/
[14] https://www.irs.gov/privacy-disclosure/safeguards-program

functions. Any function not strictly relevant for that narrow purpose is disabled.

8.7.3. **Baseline Configuration Reviews (CM-7 (1)) -** As part of setting the baseline configuration (integral part of Deployment Certification, see 8.1.4 above), information assets undergo a rigorous review with respect to enabled functions and settings. Functions not needed for official business use should be disabled by policy.

8.7.4. **Network Scanning and Intrusion Prevention (CM-7 (1)) -** The Information Security Office, in collaboration with Network Security Services, routinely utilizes network scanning tools, intrusion detection and prevention systems, and end-point protections, such as firewalls and host-based intrusion detection systems, to identify and prevent the use of prohibited functions, ports, protocols, and services.

8.7.5. **Vulnerability and Configuration Auditing (CM-7 (1)) -** The Information Security Office uses various Enterprise scanning tools to audit select information asset configurations as outlined in Vulnerability Scanning Procedure (RA-5).[15] Any non-essential function and service detected by such audits is jointly reviewed between the Information Security Office and the operational division to determine if the baseline configuration could be further tightened (by disabling unnecessary and/or unused functions, ports, protocols, and services). The CISO provides the final decision.

8.7.6. **Program Execution Controls (CM-7 (2)) -** All OIT-managed information assets reduce the likelihood of program execution in accordance with enterprise policies behind the antimalware agent resident on that information asset.

8.7.7. **Automated Detection and Removal of Unauthorized Software (CM-7 (2)) -** OIT Client Technology Services uses a configuration manager to check the network to remove software from endpoints. The configuration manager can be used for continuous network monitoring to detect the presence of unauthorized software.

8.7.8. **User Guidance for Software Installation (CM-7 (2)) -** OIT Client Technology Services customer service representatives use a knowledge management service for guidance on installing software on state-managed computers.

8.7.9. **Allow-by-Exception Software and Hardware Controls (CM-7 (5), (9)) -** The OIT Policy Team uses a new technology onboarding process to approve new software and hardware. Authorized software and hardware are identified through a formal review process prior to deployment. Enterprise deployments undergo evaluation as part of the

[15] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/VulnerablityScanningProcedure.pdf

certification process. Physical and technical controls, including port restrictions, device control software, and secured facility access, prevent connection of unauthorized hardware. The OIT Team maintains a list of approved technologies for use on the network (available upon request by emailing PolicyTeam.OIT@Maine.Gov).

8.8. Information System Component Inventory (CM-8, (1), (3))

8.8.1. **Establish and Maintain Component Inventory (CM-8) -** OIT Enterprise Data Services maintains an Enterprise Asset Inventory that documents information assets, both hardware and software. This inventory is kept up to date by the various OIT operational teams as an integral part of managing any change. Reviewing and updating the inventory is pegged to any substantial change in any information asset. The inventory also includes contact names, both technical and business.

8.8.2. **Billing Reconciliation and Accountability (CM-8) -** For any information asset whose monthly subscription is billed back, there exists a fiscal incentive for the Agency Business Management and the OIT Account Managers to scrutinize the monthly bills and vet the business needs of information assets monthly.

8.8.3. **Lifecycle Updates and Change Tracking (CM-8) -** OIT Information Asset Owners update the Enterprise Asset Inventory as an integral part of component installations, removals, and updates.

8.8.4. **Automated Unauthorized Component Detection (CM-8(1), (3)) -** Network Services employs the Cisco Identity Services Engine (ISE) to detect unauthorized information assets. When unauthorized information assets are detected, access to the Statewide area network is disabled from that information asset.

8.8.4.1. For OIT-managed servers, unauthorized installation of software is flagged by the Splunk[16] Security Information and Event Manager, managed by the Information Security Office.

8.8.5. **Automated Unauthorized Component Detection (CM-8(3)) -** For OIT-managed phones, unauthorized installation of software is flagged by Lookout,[17] managed by OIT Computing Infrastructure and Services.

8.8.6. **Responsible Individuals and Accountability (CM-8) -** The Enterprise Asset Inventory identifies the names and emails of individuals responsible and accountable for administering each of the information assets.

[16] https://www.splunk.com/
[17] https://www.lookout.com/

8.8.7. **Duplicate Accounting Prevention (CM-8) -** The Enterprise Asset Inventory enforces unique primary key requirements, which reduce the likelihood of duplicate accounting of information assets.

8.8.8. **Centralized Enterprise Asset Inventory (CM-8(7)) -** As stated above (8.7.1), OIT maintains a centralized Enterprise Asset Inventory, which documents all information assets, both hardware and software. Each asset includes contact names and emails, both technical and business, in order ensure accountability. This inventory is kept up to date by the various OIT operational teams as an integral part of managing any change.

8.8.9. **Assignment of Components to Systems (CM-8) -** In terms of the granularity of tracking components of information systems, by default, OIT Information Asset Owners track all hardware and software assets that exist on their own, including virtual servers.

8.9. **Configuration Management Plan (CM-9)**

8.9.1. **Configuration Management Plan Development (CM-9)** – Each of the OIT Information Asset Owners maintains their own configuration management plans for the information assets under their purview. Such plans explicitly include roles and responsibilities.

8.9.2. **Change Management Integration (CM-9)** – The execution of the actual configuration management, and any changes, strictly follows the Change Management Policy.[18] The configuration management approval process explicitly includes the designation of key management stakeholders responsible for reviewing and approving proposed changes to information systems, and personnel who conduct security impact analyses prior to the implementation of changes to the systems.

8.9.3. **Configuration Item Identification and Lifecycle Control (CM-9) -** Each of the OIT Information Asset Owners explicitly identifies configuration items throughout the system development lifecycles for the information assets under their purview. They define the configuration items for the information system and place them under configuration management. While configuration management applies to all stages of the system development lifecycle, it is especially important during the development/acquisition phase. However, as information systems progress through the system development lifecycle, new configuration items may be identified, and some existing configuration items may no longer require configuration control.

8.9.4. **Protection of Configuration Management Plans (CM-9) –** Each of the OIT Information Asset Owners explicitly protects their configuration plans from unauthorized disclosure and modification.

[18] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ChangeManagementPolicy.pdf

8.10. Software Usage Restrictions (CM-10, (1))

8.10.1. **Software License Compliance (CM-10) –** OIT Client Technology Services assists all State of Maine agencies to locate software and obtain associated documentation in accordance with contract agreements and copyright laws.

8.10.2. **Prohibited Use Enforcement (CM-10) –** OIT Client Technology Services assists all State of Maine agencies to control the usage of unlicensed peer-to-peer file sharing and any third-party cloud storage services on its device fleet (both operating system executable, as well as pure browser apps, across workstations, tablets, and phones) to prevent unauthorized distribution, display, performance, or reproduction of copyrighted work.

8.10.3. **Software License Tracking (CM-10) –** Software license tracking is accomplished by a combination of manual and automated methods. OIT Client Technology Services manages licenses purchased by MaineIT.

8.10.4. **Open-Source Software Risk Management (CM-10(1)) –** Open-source software is allowed on a case-by-case basis, but with the explicit message to the consumers identifying the inherent risks. All of this, and more, is documented in both the System and Services Acquisition Policy,[19] and the User Device and Commodity Application Policy.[20]

8.11. User-Installed Software (CM-11, (3))

8.11.1. **Administrative Access Restrictions (CM-11) –** End users do *not* have administrative access to the OIT-issued user devices assigned to them unless there is an agency-defined and OIT-approved legitimate business need to do so. Once software has been installed, end users may download some extensions and plug-ins that do *not* require additional administrative access.

8.11.2. **Controlled Server Software Installation (CM-11) –** Only system administrators can install software on server devices.

8.11.3. **Automated Enforcement and Monitoring (CM-11(3)) –** Enforcement and audit of this provision is executed via continuous, automated monitoring, and ingestion of all systems logs into the enterprise Security Information and Event Manager.

8.12. Information Location (CM-12, (1))

8.12.1. **Information Location Identification (CM-12)** – OIT Information Asset Owners identify and document the location of organizational information and the system components on which such information is

[19] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemAndServicesAcquisitionPolicy.pdf
[20] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/UserDeviceCommodityAppPolicy.pdf

processed and stored. Documentation includes both logical and physical locations, as well as data classification or sensitivity indicators.

8.12.2. **Access Documentation (CM-12)** – OIT Information Asset Owners document the users and system accounts that have access to systems or components where information is processed and stored. For modern systems, access control is centrally managed through directory-based identity services; legacy or standalone systems follow documented application-specific processes. Access records are maintained in accordance with access control procedures and updated as personnel or business needs change.

8.12.3. **Diagram and Inventory Maintenance (CM-12)** – The Network Operations division maintains comprehensive network diagrams reflecting current-state infrastructure and interconnections. Application Development teams create and maintain data-flow diagrams supporting regulatory compliance and operational visibility. These diagrams are reviewed and updated whenever there are significant changes to system architecture, application deployment, or data-processing locations.

8.12.4. **Automated Information Location (CM-12(1))** – Automated tools are used, where feasible, to identify and locate organization-defined information types on organization-defined system components to ensure appropriate protections are applied. Data that requires restricted handling is segmented from the remainder of the network through physical and logical segmentation. Additionally, all such data is encrypted both at rest and in transit.

8.13. **Data Action Mapping (CM-13)**

8.13.1. **System Data-Action Mapping (CM-13)** – OIT Information Asset Owners develop and maintain documented maps of system data actions that involve the processing of personally identifiable information (PII) or other regulated data. These data-action maps describe how information is collected, used, transformed, stored, transmitted, retained, and disposed of within each system, identifying the associated system components and responsible owners.

8.13.2. **Integration with System Artifacts (CM-13)** – Data-action maps are incorporated into existing system documentation artifacts, including data-flow diagrams, network diagrams, and security boundary definitions. These artifacts are reviewed and updated whenever there are material changes to system architecture, application deployment, or data-processing locations, ensuring continued accuracy and alignment between security and privacy programs.

8.14. **Signed Components (CM-14)**

8.14.1. **Control of Software and Firmware Installations (CM-14)** - Installation of software and firmware components is selectively

restricted to authorized sources and performed only by personnel with defined administrative privileges. This control prevents the introduction of unauthorized or unsigned code into OIT systems.

8.14.2. **Trusted Source Verification (CM-14)** – Software and firmware updates, including version updates, patches, service packs, device drivers, and basic input/output system (BIOS) updates, must originate from trusted repositories, vendor portals, or deployment packages validated through enterprise tools managed by OIT.

8.14.3. **Digital Signature Validation (CM-14)** – Where supported, OIT verifies digital signatures to authenticate the integrity and origin of software and firmware components. Installation is blocked if a digital signature is missing, invalid, or untrusted.

8.14.4. **Administrative Oversight (CM-14)** – Access to perform software or firmware installations is limited to designated administrative personnel. Limited privilege reviews are conducted as part of the annual access-recertification process to confirm that only authorized staff retain such rights.

9.0. Document Details

9.1. Initial Issue Date: December 18, 2020

9.2. Latest Revision Date: November 14, 2025

9.3. Point of Contact: PolicyTeam.OIT@Maine.Gov

9.4. Approved By: Chief Information Officer, OIT

9.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology[21]

9.6. Waiver Process: Waiver Policy[22]

9.7. Distribution: Internet[23]

10.0. Review

This document will be reviewed triennially, and when substantive changes are made to Policies, Procedures, or other authoritative regulations affecting this document.

11.0. Records Management

OIT security policies, plans, and procedures fall under the *Major Administrative Policies and Procedures* and *Internal Control Policies and Directives* records management categories. They will be retained for a minimum of six years after withdrawal or replacement and then destroyed in accordance with guidance[24]

[21] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[22] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[23] https://www.maine.gov/oit/policies-standards
[24] https://www.maine.gov/sos/sites/maine.gov.sos/files/content/assets/GS1Administrative.pdf

provided by Maine State Archives. Retention of these documents will be subject to any future State Archives General Schedule revisions that cover these categories.

12.0. Public Records Exceptions

Under the Maine Freedom of Access Act (FOAA),[25] certain public records exceptions may limit disclosure of agency records related to information technology infrastructure and systems, as well as security plans, procedures, or risk assessments. Information contained in these records may be disclosed to the Maine State Legislature or, in the case of a political or administrative subdivision, to municipal officials or board members under conditions that protect the information from further disclosure. Any aggrieved person seeking relief for an alleged violation of the FOAA may bring suit in any Superior Court in the State.

13.0. Definitions

13.1. Availability: Timely and reliable access to and use of information assets.

13.2. Baseline Configuration: A formally reviewed and approved set of configuration specifications for a system or component that serves as a reference point for future builds, changes, and audits.

13.3. Change Advisory Board (CAB): A formally chartered group responsible for assessing, prioritizing, approving, and scheduling proposed changes to State information systems. The CAB ensures that changes align with business priorities and risk management objectives.

13.4. Change Management Policy: The enterprise policy governing the proposal, approval, implementation, and documentation of changes to information systems, ensuring minimal disruption and traceable accountability.

13.5. Confidentiality: The state of being kept private or secret, including preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.

13.6. Configuration Item (CI): A component of an information system—such as hardware, software, documentation, or a combination thereof—that is under configuration management control.

13.7. Configuration Management Plan (CMP): A documented plan that defines the processes, responsibilities, and tools used to control and monitor configuration items across the information system lifecycle.

13.8. Configuration Settings: The set of parameters that can be changed in hardware, software, or firmware components of the information system that affect the security posture and/or functionality of the system. Information technology products for which security-related configuration settings can be defined include, for example, mainframe computers, servers (e.g., database, electronic mail, authentication, web, proxy, file, domain name), workstations, input/output devices

[25] https://legislature.maine.gov/statutes/1/title1sec402.html

(e.g., scanners, copiers, printers), network components (e.g., firewalls, routers, gateways, voice and data switches, wireless access points, network appliances, sensors), operating systems, middleware, and applications. Security-related parameters are those that impact the security of information systems, including parameters required to satisfy other security control requirements. Security-related parameters include, for example: (i) registry settings; (ii) account, file, directory permission settings; and (iii) settings for functions, ports, protocols, services, and remote connections.

13.9. Common Secure Configurations: Also referred to as security configuration checklists, lockdown and hardening guides, security reference guides, security technical implementation guides, etc. These provide recognized, standardized, and established benchmarks that stipulate secure configuration settings for specific information technology platforms and products, as well as instructions for configuring those information system components to meet operational requirements. Common secure configurations can be developed by a variety of organizations, including information technology product developers, manufacturers, vendors, consortia, academia, industry, federal agencies, and other organizations in the public and private sectors. Common secure configurations include the United States Government Configuration Baseline (USGCB). The Security Content Automation Protocol (SCAP) and the defined standards within it (e.g., Common Configuration Enumeration) provide an effective method for uniquely identifying, tracking, and controlling configuration settings.

13.10. Continuous Monitoring Program: The programmatic capability for real-time or near real-time observation, analysis, and reporting on security controls and configurations to detect unauthorized changes or deviations.

13.11. Deployment Certification: The formal OIT process that validates configurations, functionality, and security prior to operational release.

13.12. Golden Image: A standardized, preconfigured system image that serves as the authoritative source for secure deployments.

13.13. Information Asset: Used interchangeably with Information System. A discrete, identifiable piece of information technology, including hardware, software, firmware, systems, services, and related technology assets used to execute work on behalf of OIT or another State agency. (National Institute of Standards and Technology (NIST) Special Publication (SP) 800-30).

13.14. Information Asset Owner (IAO): The individual or team responsible for the overall lifecycle management, security, and compliance of a specific information asset.

13.15. Integrity: The accuracy and consistency (validity) of data over its lifecycle. Guarding the integrity of information assets against improper modification or destruction includes ensuring information nonrepudiation and authenticity.

13.16. PKI (Public Key Infrastructure): A set of roles, policies, hardware, software, and procedures that manage digital certificates. The purpose of a PKI is to facilitate the secure electronic transfer of information. More specifically, it is an arrangement

that binds public keys with the respective identities of entities (like people and organizations).

13.17. Security Information and Event Manager (SIEM): A centralized platform for collecting, analyzing, and correlating logs from systems and network devices to detect and respond to potential security incidents.

14.0. Abbreviations

14.1.	CAB:	Change Advisory Board
14.2.	CI:	Configuration Item
14.3.	CMP:	Configuration Management Plan
14.4.	EPP:	Endpoint Protection Platforms
14.5.	FOAA:	Freedom of Access Act
14.6.	IAO:	Information Asset Owner
14.7.	ISE:	Cisco Identity Services Engine
14.8.	ISO:	Information Security Office
14.9.	ITSM:	Information Technology Service Management
14.10.	NIST:	National Institute of Standards and Technology
14.11.	OIT:	Office of Information Technology
14.12.	PKI:	Public Key Infrastructure
14.13.	SCAP:	Security Control Automation Protocol
14.14.	SIEM:	Security Information and Event Manager
14.15.	SOM:	State of Maine
14.16.	USGCB:	United States Government Configuration Baseline